INFORME DE AUDITORÍA - FASE DE DIAGNÓSTICO
SILAIS MASAYA - MINISTERIO DE SALUD DE NICARAGUA

SECCIÓN 1: ANÁLISIS DEL ENTORNO OPERATIVO

1.1. Entorno Físico y Geográfico

El SILAIS Masaya opera como nodo descentralizado crítico dentro del ecosistema sanitario nacional. Su entorno físico se caracteriza por:

Distribución Espacial y Topología de Oficinas:

- **14 áreas funcionales independientes** distribuidas en un complejo administrativo-sanitario con separación física entre oficinas.
- **Oficina de Epidemiología:** Ubicada en espacio aislado con 6 estaciones de trabajo. Constituye el centro neurálgico del SISNIVEN a nivel departamental.
- **Área de Dirección:** Espacio ejecutivo con acceso a información estratégica y presupuestaria.
- **Áreas de Apoyo Administrativo:** Contabilidad, Caja, RRHH, Insumos Médicos con segregación física pero interconexión lógica plana.

Condiciones Ambientales Relevantes:

- **Clima Tropical de Masaya:** Temperaturas promedio 26-32°C con humedad relativa 70-85%.
- **Infraestructura Eléctrica Regional:** Sujeta a fluctuaciones de voltaje y cortes programados/improvisos característicos de la red nacional.
- **Polvo Volcánico Ambiental:** Proximidad al Volcán Masaya implica presencia de material particulado corrosivo para equipos electrónicos.

Distribución de Activos Tecnológicos por Área Funcional:

Área Funcional	Equipos Escritorio	Laptops	Tipo Conectividad	Datos Sensibles Procesados
Epidemiología	6	0	100% LAN	Datos SISNIVEN, brotes, mortalidad
Varios 1	10	0	LAN (Switch 24p)	Información general/diversa
Varios 2	3	0	2 LAN, 1 WLAN	Información general/diversa
Varios 3	4	0	100% LAN	Información general/diversa
Estadística	3	0	1 LAN, 2 WLAN	Datos estadísticos SISNIVEN, boletines
Contabilidad	3	0	100% WLAN	Información financiera, nóminas
RRHH	3	0	2 WLAN, 1(implícito)	Datos personales de personal sanitario
Insumos Médicos	3	0	100% WLAN	Inventario farmacéutico, caducidades
Enfermería	2	0	100% WLAN	Protocolos de atención, turnos

Área Funcional	Equipos Escritorio	Laptops	Tipo Conectividad	Datos Sensibles Procesados
Dirección/FET Salud	1	2	1 LAN, 2 WLAN	Información estratégica confidencial
SNC	2	2	Conexión Privada	Datos de salud comunitarios sensibles
Administración	1	0	LAN	Información presupuestaria
Caja	2	0	LAN	Transacciones financieras
Banco Biológico	1	0	LAN	Muestras biológicas, resultados VIH/TB
Sindicato	2	0	Conexión Privada	Información gremial
Transporte	0	1	Conexión Privada	Logística operativa
TOTAL	**46**	**5**		

1.2. Entorno Tecnológico - Análisis de Infraestructura Crítica

1.2.1. Capa de Acceso y Conmutación

Componente Documentado:

- **2 Switches Fast Ethernet de 24 puertos**
- Velocidad nominal: 100 Mbps (Megabits por segundo)
- Estándar tecnológico: IEEE 802.3u (Ratificado en 1995)

Análisis de Capacidad Real vs. Demanda Operativa:

Parámetro Técnico	Capacidad Switch Actual	Requerimiento Mínimo Moderno	Déficit Operativo
Ancho de Banda por Puerto	100 Mbps	1000 Mbps (Gigabit)	**90% de pérdida de rendimiento**
Capacidad de Switching Fabric	~4.8 Gbps (estimado)	48-56 Gbps	**Factor 10x de estrangulamiento**
Throughput de Paquetes	6.5 Mpps (máx teórico)	35.7-71.4 Mpps	**82% de pérdida de capacidad de procesamiento**
Búfer de Memoria por Puerto	64-128 KB	1.5-12 MB	**Congestión severa en ráfagas de datos**
Soporte VLAN (802.1Q)	No documentado/Improbable	Requerido para segmentación	**Ausencia de segmentación lógica**

Parámetro Técnico	Capacidad Switch Actual	Requerimiento Mínimo Moderno	Déficit Operativo
Calidad de Servicio (QoS)	Limitada/Ausente	Requerida para voz/datos clínicos	**Latencia impredecible en aplicaciones críticas**
Administración Remota (SNMP)	Desconocida	Requerida para monitoreo	**Ceguera operacional en gestión de red**

1.2.2. Capa de Acceso Inalámbrico (WLAN)

Distribución Documentada de Conexiones Inalámbricas:

- **Estadística:** 2 de 3 equipos operando por WiFi
- **Contabilidad:** 3 equipos - 100% dependencia WiFi
- **Insumos Médicos:** 3 equipos - 100% dependencia WiFi
- **Enfermería:** 2 equipos - 100% dependencia WiFi
- **RRHH:** 2 de 3 equipos por WiFi
- **Dirección:** 2 laptops por WiFi

Total Equipos con Dependencia WiFi para Funciones Críticas: 15 equipos (29.4% del parque total)

Características del Entorno Inalámbrico No Documentadas (Requieren Verificación In-Situ):

- Estándar WiFi utilizado (802.11n, ac, ax)
- Cifrado implementado (WPA2-PSK, WPA3-Enterprise)
- Número de Puntos de Acceso
- Cobertura real en áreas de Estadística y Contabilidad
- Interferencia de redes adyacentes o equipos médicos

1.2.3. Topología de Red y Arquitectura Lógica

Estructura Jerárquica Documentada:

[ISP MINSA Central]

↓

[Router de Borde - No Documentado]

↓

[Switch Principal - Ubicado en Dirección]

↓

↓ ↓ ↓ ↓

[Switch 24p] [Oficinas] [WiFi AP] [Conexiones Privadas]

Varios 1 LAN WLAN Sindicato/SNC

Análisis de Segmentación Lógica:

Estado Actual: RED PLANA (Flat Network)

- **Dominio de Broadcast Único:** Todos los 51 equipos conectados a la infraestructura LAN/WLAN comparten el mismo segmento de red lógico.
- **Rango de Direccionamiento IP Estimado:** /24 (254 hosts máximo) - Suficiente para la cantidad actual pero sin capacidad de aislamiento.
- **Ausencia de VLANs Documentadas:** No existe evidencia de separación lógica entre:
    - Datos Clínicos Sensibles (Epidemiología, Banco Biológico)
    - Datos Administrativo-Financieros (Contabilidad, Caja, RRHH)
    - Datos Operativos (Enfermería, Insumos Médicos)
    - Acceso de Terceros/Visitantes

1.2.4. Endpoints y Estaciones de Trabajo

Perfil de Hardware de Escritorio (46 unidades):

- **Antigüedad Estimada:** No documentada en el inventario proporcionado
- **Sistema Operativo:** No documentado (Windows 7/10/11 o Linux)
- **Tarjeta de Red:** Gigabit Ethernet (1000 Mbps) - **Operando forzada a 100 Mbps por limitación del switch**
- **Software de Seguridad:** No documentado (Antivirus, Endpoint Protection)
- **Cifrado de Disco:** No documentado (BitLocker, LUKS, VeraCrypt)

Perfil de Laptops (5 unidades):

- **Distribución:** Dirección (2), SNC (2), Transporte (1)
- **Movilidad:** Representan vectores de entrada/salida de datos del perímetro de la red
- **Conectividad Externa:** 3 equipos con "Conexión Privada" fuera del control del SILAIS

SECCIÓN 2: IDENTIFICACIÓN DE AMENAZAS

2.1. Matriz de Amenazas Clasificadas por Origen y Vector de Ataque

2.1.1. Amenazas de Origen Físico y Ambiental

ID Amenaza	Descripción Detallada	Vector de Materialización	Probabilidad Base	Áreas Afectadas
A-PHY-001	**Fluctuaciones Eléctricas y Apagones** - Inestabilidad del suministro	Descargas atmosféricas, desconexiones programadas por ENEL, sobrecarga	Alta (Mensual)	100% de equipos sin UPS/Batería de respaldo

ID Amenaza	Descripción Detallada	Vector de Materialización	Probabilidad Base	Áreas Afectadas
	eléctrico nacional en Masaya	de transformadores		
A-PHY-002	**Polvo Volcánico Corrosivo** - Material particulado del Volcán Masaya con componentes sulfurosos	Acumulación progresiva en ventiladores, fuentes de poder, contactos de placa base	Alta (Permanente)	Switches (2), PCs de escritorio (46)
A-PHY-003	**Humedad Relativa Elevada (70-85%)** - Condición climática de Masaya	Oxidación acelerada de contactos metálicos, cortocircuitos por condensación	Media-Alta (Estacional)	Equipos sin climatización adecuada
A-PHY-004	**Acceso Físico No Controlado a Puertos de Red** - Puertos LAN expuestos en áreas de "Varios"	Conexión no autorizada de equipos personales o dispositivos maliciosos	Media	Switch 24p en Varios 1, puertos expuestos

ID Amenaza	Descripción Detallada	Vector de Materialización	Probabilidad Base	Áreas Afectadas
A-PHY-005	**Fallo Catastrófico de Switch Principal** - Agotamiento de vida útil de equipo Fast Ethernet (25+ años de antigüedad tecnológica)	Falla de fuente de poder, capacitores electrolíticos degradados, sobrecalentamiento	Alta (Inminente)	

2.1.2. Amenazas de Origen Lógico y Cibernético

ID Amenaza	Descripción Detallada	Vector de Ataque Específico	Probabilidad	Impacto Potencial
A-LOG-001	**Ransomware dirigido al Sector Salud** - Ataque de cifrado de datos con extorsión específica para SILAIS latinoamericanos	Phishing a correos institucionales, descarga de adjuntos maliciosos, explotación de vulnerabilidades SMB en Windows sin parches	Alta	Crítico - Paralización SISNIVEN
A-LOG-002	**Exfiltración de Datos de**	Movimiento lateral desde	Media	Crítico - Violación de

ID Amenaza	Descripción Detallada	Vector de Ataque Específico	Probabilidad	Impacto Potencial
	Pacientes (SISNIVEN) - Robo silencioso de registros epidemiológicos para venta en mercados negros	equipo comprometido en "Varios 1" hacia servidor de Epidemiología		confidencialidad masiva
A-LOG-003	**Ataque Man-in-the-Middle (MitM) en WiFi** - Interceptación de tráfico inalámbrico sin cifrado robusto	Sniffing pasivo de credenciales de acceso a sistemas del MINSA desde Estadística o Contabilidad	Media-Alta	Alto - Compromiso de cuentas privilegiadas
A-LOG-004	**Propagación de Malware por Dispositivos USB** - Vector tradicional en entornos sanitarios con baja concienciación	Uso compartido de memorias USB entre equipos de Epidemiología y equipos personales	Alta	Medio-Alto - Infección progresiva de endpoints
A-LOG-005	**Denegación de Servicio (DoS) Interna por Broadcast Storm** -	Mal funcionamiento de una tarjeta de red en	Media	Alto - Caída total de conectividad LAN

ID Amenaza	Descripción Detallada	Vector de Ataque Específico	Probabilidad	Impacto Potencial
	Colapso de la red por saturación de tráfico de difusión en red plana	cualquier PC de "Varios"		
A-LOG-006	**Acceso No Autorizado a "Conexiones Privadas"** - Uso indebido de accesos dedicados de Sindicato/SNC para evadir controles	Ingeniería social para obtener credenciales WiFi de conexiones alternativas	Baja-Media	Medio - Fuga de información no monitoreada

2.1.3. Amenazas de Origen Humano

ID Amenaza	Descripción Detallada	Perfil del Agente	Probabilidad	Motivación
A-HUM-001	**Error Humano en Configuración de Switch** - Modificación accidental que cause caída de	Personal técnico sin capacitación en equipos legacy Fast Ethernet	Media	Accidental / Falta de documentación

ID Amenaza	Descripción Detallada	Perfil del Agente	Probabilidad	Motivación
	segmentos de red			
A-HUM-002	**Exposición Involuntaria de Datos por WiFi Abierto** - Usuario de Estadística conectándose a red sin cifrado	Personal con bajo nivel de concienciación en ciberseguridad	Media	Desconocimiento
A-HUM-003	**Sabotaje Interno por Personal Descontento** - Borrado intencional de configuraciones o datos	Personal en proceso de rotación (ver cambios 2023-2025 en organigrama)	Baja	Descontento laboral / Represalia
A-HUM-004	**Robo Físico de Equipos Portátiles** - Sustracción de laptops de Dirección o SNC	Delincuencia común en área de Masaya	Media	Valor económico del equipo + Datos sensibles
A-HUM-005	**Ingeniería Social Telefónica** -	Actores externos con conocimiento	Media	Obtención de credenciales o

ID Amenaza	Descripción Detallada	Perfil del Agente	Probabilidad	Motivación
	Suplantación de identidad de personal del MINSA Central	básico del organigrama del SILAIS		información sensible

2.1.4. Amenazas Específicas por Área Funcional Crítica

ÁREA: EPIDEMIOLOGÍA (SISNIVEN)

Amenaza Específica	Vector	Consecuencia Directa
Interrupción de transmisión de datos al MINSA Central	Switch Fast Ethernet congestionado en hora pico	Retraso en alertas epidemiológicas nacionales
Manipulación de datos de brotes	Acceso desde equipo comprometido en red plana	Falsificación de estadísticas de salud pública
Pérdida de histórico de vigilancia	Ransomware cifrando archivos locales de las 6 PCs	Imposibilidad de análisis retrospectivo de enfermedades

ÁREA: ESTADÍSTICA

Amenaza Específica	Vector	Consecuencia Directa
Corrupción de datos durante sincronización	Interferencia/caída de señal WiFi en momento crítico	Boletines epidemiológicos semanales con errores

Amenaza Específica	Vector	Consecuencia Directa
Interceptación de credenciales de acceso al sistema central	Ataque MitM en red WiFi potencialmente débil	Acceso no autorizado a repositorio nacional de estadísticas

ÁREA: INSUMOS MÉDICOS

Amenaza Específica	Vector	Consecuencia Directa
Alteración de inventario farmacéutico	Acceso no autorizado vía WiFi desde área externa	Desabastecimiento de medicamentos críticos
Exposición de caducidades de vacunas	Pérdida de conectividad WiFi en momento de despacho	Aplicación de biológicos vencidos a población

ÁREA: BANCO BIOLÓGICO

Amenaza Específica	Vector	Consecuencia Directa
Divulgación de resultados VIH/TB	Acceso no segmentado desde cualquier PC de la red plana	Violación de confidencialidad de pacientes seropositivos
Alteración de resultados de laboratorio	Compromiso del único PC del área	Diagnósticos erróneos con consecuencias clínicas graves

SECCIÓN 3: IDENTIFICACIÓN DE VULNERABILIDADES

3.1. Vulnerabilidades de Infraestructura de Red - Nivel Crítico

ID Vuln	Vulnerabilidad Técnica Específica	CWE/CVE Relacionado	Evidencia en SILAIS Masaya	Explotabilidad
V-NET-001	**Obsolescencia Tecnológica Severa - Fast Ethernet (100 Mbps)**	N/A - Obsolecencia de Diseño	2 Switches Fast Ethernet de 24p constituyen el 100% del núcleo de conmutación	**MUY ALTA** - Degradación continua
V-NET-002	**Topología de Red Plana (Sin Segmentación VLAN)**	CWE-923: Ausencia de restricciones de acceso a endpoints	Todas las oficinas en mismo dominio de broadcast sin ACLs	**MUY ALTA** - Movimiento lateral trivial
V-NET-003	**Gestión de Switches Sin Autenticación Robusta**	CWE-287: Autenticación inapropiada	Interfaces de administración de switches potencialmente con credenciales por defecto o compartidas	**ALTA** - Acceso administrativo no controlado
V-NET-004	**Ausencia de Monitoreo de Red (SNMP, NetFlow)**	CWE-778: Registro de eventos de	Sin visibilidad de tráfico malicioso, congestión o	**ALTA** - Ceguera operacional completa

ID Vuln	Vulnerabilidad Técnica Específica	CWE/CVE Relacionado	Evidencia en SILAIS Masaya	Explotabilidad
		seguridad insuficiente	intentos de acceso no autorizado	
V-NET-005	**Dependencia WiFi para Funciones Críticas (29.4% de equipos)**	CWE-311: Ausencia de cifrado de datos sensibles en tránsito	Estadística, Contabilidad, Insumos Médicos, RRHH operando con conectividad no garantizada	**ALTA** - Intermitencia y exposición
V-NET-006	**Conexiones "Privadas" Fuera del Perímetro de Seguridad**	CWE-501: Violación de límite de confianza	Sindicato, SNC, Transporte con accesos a Internet no auditados por TI del SILAIS	**MEDIA-ALTA** - Bypass de controles
V-NET-007	**Punto Único de Falla - Switch Principal en Dirección**	CWE-1061: Dependencia de componente único	Toda la red LAN depende de un equipo Fast Ethernet sin redundancia documentada	**CRÍTICA** - Fallo catastrófico
V-NET-008	**Cableado Estructurado de Categoría Desconocida**	N/A - Infraestructura física	Posible cableado Cat5 o inferior limitando cualquier	**MEDIA** - Cuello de botella persistente

ID Vuln	Vulnerabilidad Técnica Específica	CWE/CVE Relacionado	Evidencia en SILAIS Masaya	Explotabilidad
			mejora futura de velocidad	

3.2. Vulnerabilidades de Endpoints y Estaciones de Trabajo

ID Vuln	Vulnerabilidad Técnica Específica	Evidencia en SILAIS Masaya	Explotabilidad
V-END-001	**Sistemas Operativos Sin Parches de Seguridad**	46 PCs de escritorio sin gestión centralizada de actualizaciones documentada	**ALTA** - Vulnerabilidades conocidas explotables
V-END-002	**Ausencia de Endpoint Protection (Antivirus/EDR)**	Sin evidencia de software de protección en inventario proporcionado	**CRÍTICA** - Primera línea de defensa inexistente
V-END-003	**Discos Duros Sin Cifrado**	Datos de SISNIVEN y Banco Biológico almacenados en texto claro	**ALTA** - Exposición en caso de robo de equipo
V-END-004	**Puertos USB Habilitados Sin Restricciones**	Vector documentado de entrada de malware en entornos sanitarios	**ALTA** - Propagación de malware por medios removibles

ID Vuln	Vulnerabilidad Técnica Específica	Evidencia en SILAIS Masaya	Explotabilidad
V-END-005	**Conexiones WiFi Configuradas con WPA2-PSK Compartido**	Contabilidad, Estadística, Insumos Médicos potencialmente usando misma clave WiFi	**MEDIA-ALTA** - Clave comprometida expone a todos
V-END-006	**Equipos Operando Forzados a 100 Mbps**	46 PCs con capacidad Gigabit estranguladas por switch Fast Ethernet	**BAJA** (Funcional) - **ALTA** (Rendimiento) - Estrangulamiento operativo

3.3. Vulnerabilidades Organizacionales y de Procesos

ID Vuln	Vulnerabilidad de Proceso/Organizacional	Evidencia en Contexto del SILAIS Masaya	Impacto en Seguridad
V-ORG-001	**Ausencia de Política de Seguridad de la Información Documentada**	No se menciona marco normativo interno de TI en la documentación del SILAIS	**CRÍTICO** - Sin gobierno de seguridad
V-ORG-002	**Alta Rotación de Personal en Cargos Clave (2023-2025)**	8 cambios documentados en posiciones de responsabilidad en 4 años	**MEDIO-ALTO** - Pérdida de conocimiento y control de accesos

ID Vuln	Vulnerabilidad de Proceso/Organizacional	Evidencia en Contexto del SILAIS Masaya	Impacto en Seguridad
V-ORG-003	**Falta de Personal Dedicado a TI/Sistemas**	No aparece responsable de TI/Sistemas en el organigrama detallado del SILAIS	**CRÍTICO** - Sin propietario de la infraestructura
V-ORG-004	**Falta de Concienciación en Ciberseguridad para Personal Sanitario**	Enfoque documentado en auditorías de calidad médica, no en seguridad informática	**ALTO** - Factor humano como eslabón más débil
V-ORG-005	**Inexistencia de Plan de Continuidad de Negocio (BCP) para TI**	Sin evidencia de procedimiento ante fallo de switches o ataque de ransomware	**CRÍTICO** - Respuesta improvisada ante incidentes
V-ORG-006	**Falta de Inventario de Activos de Software**	Sin registro de licencias, versiones de sistemas operativos o aplicaciones críticas	**MEDIO** - Superficie de ataque desconocida
V-ORG-007	**Rotación Reciente en Dirección de Servicios de Salud**	Dra. Tiátira Gómez asume 01/Nov/2024 - Transición de conocimiento en curso	**BAJO-MEDIO** - Ventana de oportunidad para consolidar mejoras

3.4. Vulnerabilidades Específicas del Marco Regulatorio SISNIVEN

ID Vuln	Vulnerabilidad Regulatoria	Requisito MINSA/SISNIVEN Potencialmente Vulnerado	Consecuencia
V-REG-001	**Transmisión de Datos Epidemiológicos en Canal No Cifrado**	Confidencialidad de datos de vigilancia epidemiológica nacional	Exposición de brotes antes de comunicación oficial
V-REG-002	**Almacenamiento Local de Datos de Pacientes en PCs de Escritorio**	Custodia de expedientes clínicos según PNS 2008	Pérdida irreversible de historial clínico en caso de fallo
V-REG-003	**Falta de Trazabilidad en Modificaciones de Datos Estadísticos**	Integridad de boletines epidemiológicos semanales	Manipulación no detectable de estadísticas de salud pública
V-REG-004	**Acceso No Controlado a Resultados de Banco Biológico**	Confidencialidad de resultados VIH/TB según marco legal nicaragüense	Violación de derechos de pacientes seropositivos

SECCIÓN 4: EVALUACIÓN Y CUANTIFICACIÓN DE RIESGOS

4.1. Metodología de Evaluación de Riesgos Aplicada

Se aplica metodología **MAGERIT v3 adaptada al sector salud**, complementada con **NIST SP 800-30 Rev. 1**, utilizando la siguiente escala:

Probabilidad de Ocurrencia:

Nivel	Valor	Descripción
Muy Alta	5	Ocurrencia inminente (semanas) o certeza virtual
Alta	4	Ocurrencia probable (meses) basada en contexto y amenazas activas
Media	3	Ocurrencia posible (1-2 años)
Baja	2	Ocurrencia poco probable (3-5 años)
Muy Baja	1	Ocurrencia excepcional

Impacto en la Misión del SILAIS:

Nivel	Valor	Descripción
Catastrófico	5	Paralización total del SISNIVEN departamental, pérdida de vidas humanas indirecta
Crítico	4	Interrupción mayor de servicios de vigilancia, daño reputacional severo al MINSA
Alto	3	Interrupción significativa de operaciones, pérdida de datos sensibles
Medio	2	Interrupción parcial, recuperable en horas/días
Bajo	1	Molestia operativa menor, sin impacto en la misión

Matriz de Riesgo:

Probabilidad / Impacto	Bajo (1)	Medio (2)	Alto (3)	Crítico (4)	Catastrófico (5)
Muy Alta (5)	5	10	15	20	**25**
Alta (4)	4	8	12	**16**	**20**

Probabilidad / Impacto	Bajo (1)	Medio (2)	Alto (3)	Crítico (4)	Catastrófico (5)
Media (3)	3	6	9	**12**	**15**
Baja (2)	2	4	6	8	10
Muy Baja (1)	1	2	3	4	5

Niveles de Riesgo:

- **EXTREMO (16-25):** Requiere acción inmediata de Dirección General
- **ALTO (10-15):** Requiere atención prioritaria y plan de mitigación urgente
- **MEDIO (5-9):** Requiere monitoreo y acción planificada
- **BAJO (1-4):** Aceptable con controles existentes

4.2. Matriz de Riesgos Identificados y Valorados

RIESGOS DE NIVEL EXTREMO (16-25) - ACCIÓN INMEDIATA REQUERIDA

ID Riesgo	Descripción del Riesgo	P	I	Valor	Justificación de Valoración
R-EXT-001	**Colapso Catastrófico del Switch Principal Fast Ethernet** - Falla total del equipo legacy que sostiene la red LAN del SILAIS, dejando sin conectividad a Epidemiología, Estadística, Administración y todas las áreas misionales	5	5	**25**	**Probabilidad Muy Alta:** Equipo con 15-25 años de antigüedad tecnológica operando en ambiente tropical con polvo volcánico y sin mantenimiento documentado. **Impacto Catastrófico:** Parálisis total de vigilancia epidemiológica departamental durante 3-5 días mínimo (tiempo de adquisición de repuesto en Nicaragua)
R-EXT-002	**Ataque de Ransomware Propagado por Red Plana a Datos SISNIVEN** - Infección iniciada en PC de "Varios 1" que se propaga sin restricción a equipos de Epidemiología y Banco Biológico, cifrando datos críticos de vigilancia epidemiológica	4	5	**20**	**Probabilidad Alta:** Sector salud nicaragüense en punto de mira de ciberdelincuentes latinoamericanos; red plana permite propagación sin barreras; falta de endpoint protection y backups documentados. **Impacto Catastrófico:** Pérdida de histórico epidemiológico departamental; imposibilidad de reportar al MINSA Central; daño reputacional internacional

ID Riesgo	Descripción del Riesgo	P	I	Valor	Justificación de Valoración
R-EXT-003	**Exfiltración Masiva de Datos Confidenciales de Pacientes del Banco Biológico** - Acceso no autorizado desde cualquier punto de la red plana al único PC del Banco Biológico conteniendo resultados VIH/TB de la población de Masaya	3	5	**15**	**Probabilidad Media:** Requiere compromiso previo de un endpoint; sin embargo, la red plana y falta de segmentación hacen trivial el acceso una vez dentro. **Impacto Catastrófico:** Violación masiva de confidencialidad de datos de salud protegidos por ley; crisis de confianza pública en el sistema de salud departamental

RIESGOS DE NIVEL ALTO (10-15) - ATENCIÓN PRIORITARIA URGENTE

ID Riesgo	Descripción del Riesgo	P	I	Valor	Justificación de Valoración
R-ALT-001	**Interrupción Prolongada de Conectividad en Estadística por Dependencia WiFi** - Caída o interferencia de señal inalámbrica durante ventana crítica de consolidación de datos para boletín epidemiológico semanal del MINSA	4	3	**12**	**Probabilidad Alta:** 2 de 3 PCs en Estadística dependen de WiFi; entorno con potencial interferencia; sin redundancia. **Impacto Alto:** Retraso en reporte obligatorio al MINSA Central; incumplimiento de normativa de vigilancia epidemiológica nacional
R-ALT-002	**Pérdida de Datos Financieros y de Nómina en Contabilidad** - Corrupción o ransomware afectando las 3 PCs de Contabilidad conectadas 100% por WiFi sin backups documentados	4	3	**12**	**Probabilidad Alta:** 100% dependencia WiFi sin redundancia; área con datos sensibles de personal y presupuesto. **Impacto Alto:** Incapacidad de procesar nóminas del personal sanitario; caos administrativo y descontento laboral
R-ALT-003	**Manipulación No Detectada de Datos de Vigilancia Epidemiológica** - Actor interno o externo modifica registros de brotes o mortalidad en PCs de	3	4	**12**	**Probabilidad Media:** Acceso físico/lógico potencial desde red plana. **Impacto Crítico:** Falsificación de estadísticas de salud

ID Riesgo	Descripción del Riesgo	P	I	Valor	Justificación de Valoración
	Epidemiología sin trazabilidad de auditoría				pública; decisiones de política sanitaria basadas en datos corruptos; riesgo de ocultamiento de brotes reales
R-ALT-004	**Robo de Laptop de Dirección con Datos Estratégicos** - Sustracción física de equipo portátil de Dirección conteniendo información confidencial del SILAIS sin cifrado de disco	3	4	**12**	**Probabilidad Media:** Índices de criminalidad en Masaya; movilidad del equipo. **Impacto Crítico:** Exposición de planes estratégicos, presupuestos, y comunicaciones confidenciales con MINSA Central
R-ALT-005	**Tormenta de Broadcast Paralizando la Red LAN** - Saturación del switch Fast Ethernet por tráfico de difusión excesivo generado por una tarjeta de red defectuosa o ataque interno	3	3	**9**	**Probabilidad Media:** Vulnerabilidad inherente a redes planas sin segmentación. **Impacto Alto:** Caída total de conectividad LAN por horas mientras se identifica y aísla el origen manualmente
R-ALT-006	**Desabastecimiento de Insumos Médicos por Fallo de Conectividad** - Interrupción de acceso al	4	3	**12**	**Probabilidad Alta:** Dependencia WiFi sin redundancia en área operativa

ID Riesgo	Descripción del Riesgo	P	I	Valor	Justificación de Valoración
	sistema de inventario farmacéutico desde las 3 PCs de Insumos Médicos (100% WiFi) en momento crítico de despacho				crítica. **Impacto Alto:** Retraso en entrega de medicamentos a unidades de salud periféricas; afectación a pacientes
R-ALT-007	**Compromiso de Credenciales de Acceso al SISNIVEN Central vía WiFi** - Interceptación de contraseñas de usuarios de Estadística/Epidemiología mediante ataque Man-in-the-Middle en red inalámbrica con cifrado débil	3	4	**12**	**Probabilidad Media:** Requiere proximidad física y configuración WiFi débil. **Impacto Crítico:** Acceso no autorizado al repositorio nacional de vigilancia epidemiológica; potencial manipulación de datos a nivel nacional

RIESGOS DE NIVEL MEDIO (5-9) - REQUIERE MONITOREO Y ACCIÓN PLANIFICADA

ID Riesgo	Descripción del Riesgo	P	I	Valor
R-MED-001	**Fuga de Información a través de "Conexiones Privadas" No Auditadas** - Datos sensibles del SILAIS exfiltrados vía conexiones de Sindicato/SNC/Transporte fuera del control de TI	2	4	**8**

ID Riesgo	Descripción del Riesgo	P	I	Valor
R-MED-002	**Error de Configuración en Switch por Personal No Capacitado** - Modificación accidental durante intento de mantenimiento que cause caída de segmentos de red	3	3	**9**
R-MED-003	**Infección Progresiva por Malware vía Dispositivos USB** - Propagación lenta de malware entre PCs de diferentes oficinas a través de memorias USB compartidas	4	2	**8**
R-MED-004	**Degradación Crónica de Rendimiento por Congestión Fast Ethernet** - Lentitud progresiva en acceso a aplicaciones centrales del MINSA por saturación de enlaces de 100 Mbps	5	2	**10**
R-MED-005	**Pérdida de Datos por Fallo de Disco Duro en PC de Escritorio** - Falla mecánica de disco en equipo de Epidemiología sin backup documentado	3	3	**9**
R-MED-006	**Acceso No Autorizado a Puertos LAN Expuestos en Áreas "Varios"** - Conexión de equipo personal o dispositivo no autorizado a puertos de red activos sin control de acceso (802.1X)	3	3	**9**

RIESGOS DE NIVEL BAJO (1-4) - ACEPTABLE CON CONTROLES EXISTENTES

ID Riesgo	Descripción del Riesgo	P	I	Valor
R-BAJ-001	**Sabotaje Interno Deliberado por Personal** - Acción maliciosa de empleado descontento contra sistemas de información	1	4	**4**
R-BAJ-002	**Ingeniería Social Telefónica Exitosa** - Suplantación de identidad del MINSA Central para obtener credenciales	2	2	**4**
R-BAJ-003	**Daño por Descarga Atmosférica Directa** - Impacto de rayo en instalaciones del SILAIS	1	3	**3**

4.4. Mapa de Calor de Riesgos por Área Funcional

Área Funcional	Riesgo Extremo	Riesgo Alto	Riesgo Medio	Riesgo Bajo	**Índice de Riesgo Compuesto**
Epidemiología	2	2	2	0	**CRÍTICO**
Estadística	0	3	1	0	**ALTO-CRÍTICO**
Banco Biológico	1	0	0	0	**EXTREMO**

Área Funcional	Riesgo Extremo	Riesgo Alto	Riesgo Medio	Riesgo Bajo	**Índice de Riesgo Compuesto**
Dirección General	0	1	0	0	**ALTO**
Contabilidad	0	1	1	0	**ALTO**
Insumos Médicos	0	1	0	0	**ALTO**
Infraestructura de Red	1	0	3	0	**EXTREMO**
Varios 1/2/3	0	0	2	0	**MEDIO**
SNC/Sindicato	0	0	1	0	**MEDIO**

SECCIÓN 5: CONCLUSIONES DEL DIAGNÓSTICO

5.1. Juicio Técnico del Auditor

El SILAIS Masaya presenta una **situación de Riesgo Tecnológico Inaceptable para una Institución de Salud Pública Departamental**. La infraestructura tecnológica que soporta las funciones críticas de vigilancia epidemiológica (SISNIVEN), atención integral a la mujer y niñez, y gestión de insumos médicos, opera en un estado de:

1. **Obsolescencia Tecnológica Crítica:** Los switches Fast Ethernet de 100 Mbps constituyen un estrangulamiento operativo documentado que desperdicia el 90% de la capacidad del hardware de escritorio adquirido y pone en riesgo la transmisión oportuna de datos al MINSA Central.

2. **Vulnerabilidad Estructural de Seguridad:** La topología de red plana sin segmentación VLAN representa una violación de los principios fundamentales de seguridad de la información en entornos sanitarios (ISO 27799). Un compromiso en cualquier punto de la red expone la totalidad de los datos clínicos y administrativos del SILAIS.
3. **Dependencia Operativa de Conectividad No Garantizada:** El 29.4% de los equipos en funciones críticas (Estadística, Contabilidad, Insumos Médicos) operan exclusivamente sobre WiFi sin redundancia, introduciendo un vector de fallo evitable en procesos misionales.
4. **Vacío de Gobernanza Tecnológica:** La ausencia de un responsable de TI/Sistemas en el organigrama detallado, combinada con la falta de políticas documentadas de seguridad y continuidad, deja al SILAIS Masaya sin capacidad de respuesta estructurada ante incidentes.

5.2. Declaración de No Conformidad con Estándares Internacionales

Con base en la evidencia documental analizada, el SILAIS Masaya presenta **No Conformidades Mayores** con los siguientes marcos de referencia:

Estándar / Marco	Cláusula / Control Vulnerado	Evidencia de No Conformidad
ISO/IEC 27001:2022	A.8.20 - Segregación de Redes	Topología plana sin VLANs
ISO/IEC 27001:2022	A.8.22 - Seguridad en Comunicaciones	Transmisión de datos epidemiológicos sin cifrado documentado
ISO/IEC 27001:2022	A.8.24 - Uso de Criptografía	Discos duros sin cifrado; WiFi sin WPA3-Enterprise
COBIT 2019	BAI09 - Gestión de Activos	Sin inventario documentado de software y configuraciones

Estándar / Marco	Cláusula / Control Vulnerado	Evidencia de No Conformidad
COBIT 2019	DSS05 - Gestión de Servicios de Seguridad	Sin monitoreo de red ni detección de intrusiones
NIST SP 800-53 Rev.5	SC-7 - Boundary Protection	Ausencia de firewalls o ACLs entre segmentos de red
NIST SP 800-53 Rev.5	CP-2 - Contingency Plan	Sin Plan de Continuidad de Negocio para infraestructura TI